

TECHNICAL DETAIL

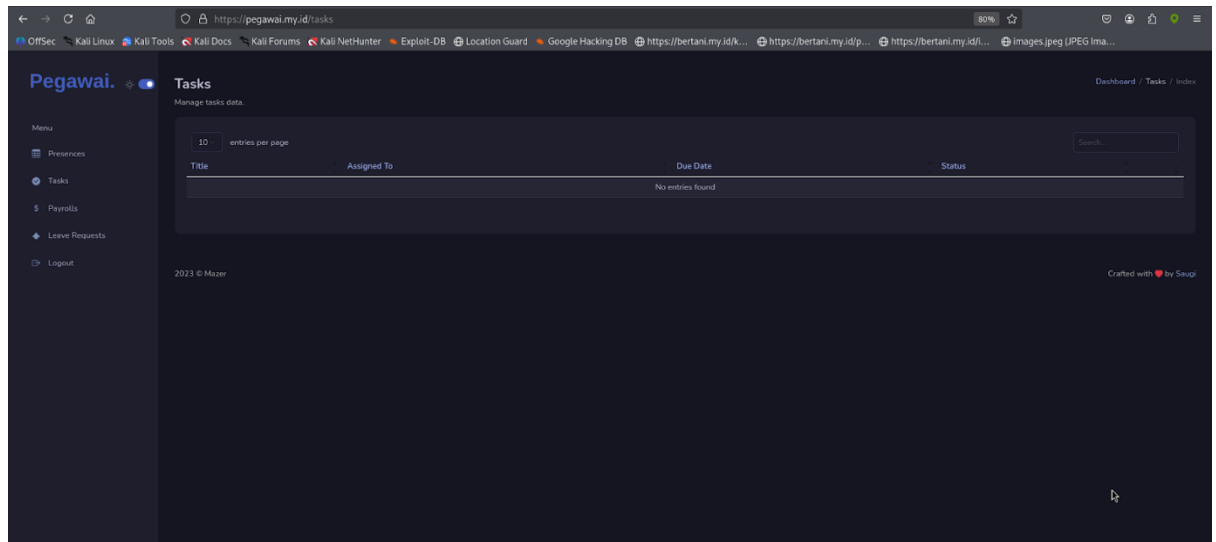
Title	Broken Access Control: Unauthorized Task Creation and Assignment to Other Users
Reporter	Daffa Rahadya Atmawiguna (rahadya.daffaa@gmail.com)
Date	2025-12-28
Affected Asset	https://pegawai.my.id/tasks/create
Severity	Medium
CVSS Score	4.3 (CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:N)
Proof of Concepts	Please see Steps to Reproduce section

SUMMARY

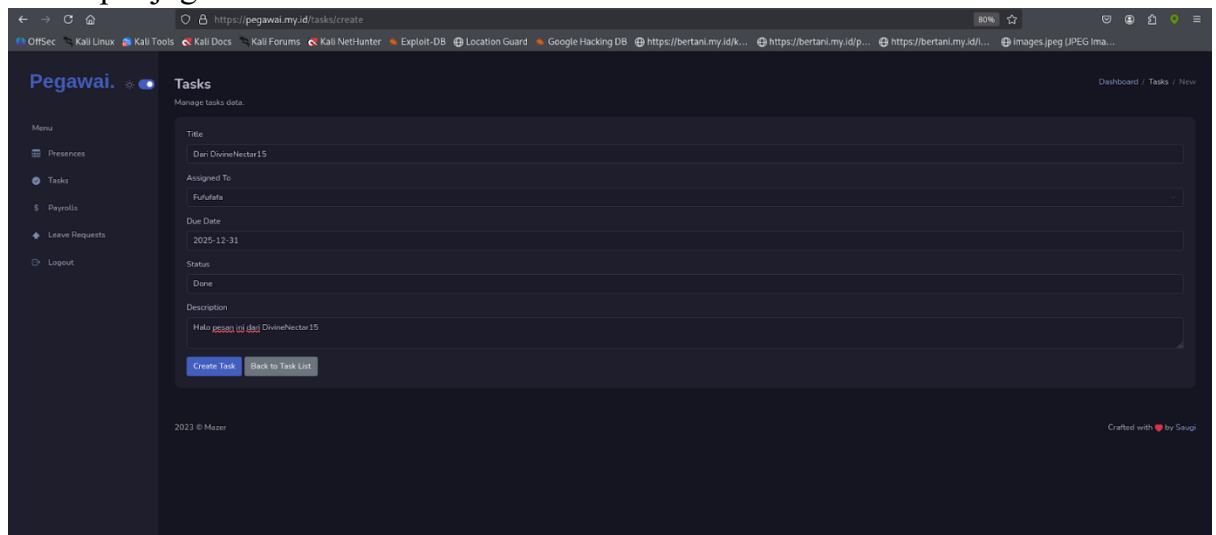
Ditemukan kerentanan Broken Access Control pada fitur Manajemen Tugas (*Tasks*) di platform pegawai.my.id. Pengguna dengan peran rendah (seperti *Developer*) dapat melakukan Force Browsing ke endpoint `/tasks/create` yang seharusnya tidak tersedia di antarmuka mereka. Celah ini memungkinkan pengguna tersebut untuk membuat tugas baru dan secara bebas menetapkannya kepada pengguna lain di dalam organisasi tanpa memerlukan hak akses administratif.

STEPS TO REPRODUCE

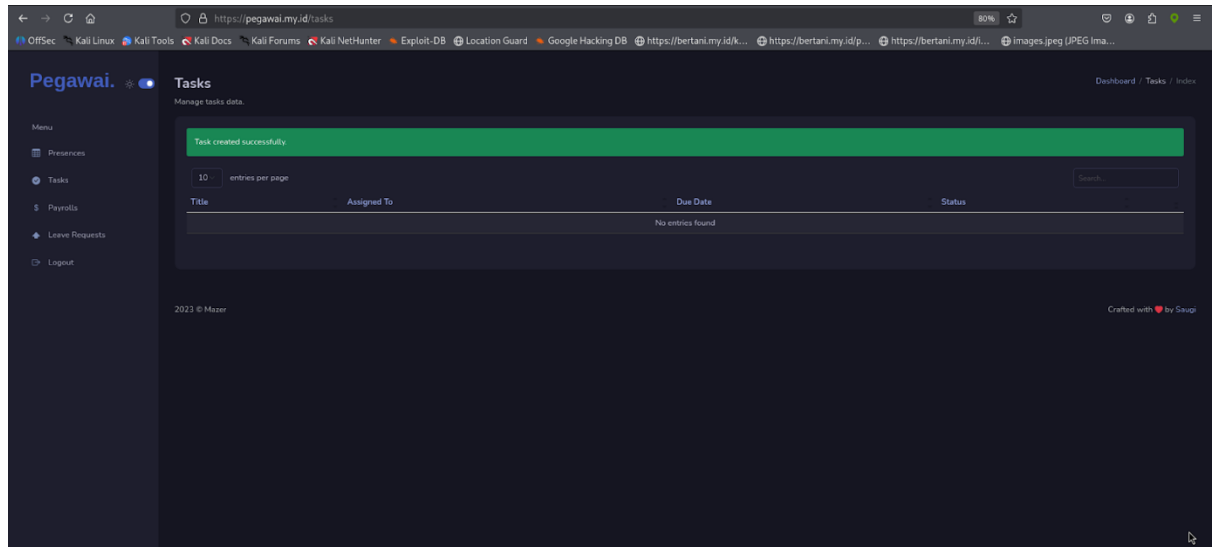
1. Login ke akun Anda yang memiliki role developer
2. Buka url <https://pegawai.my.id/tasks> terlihat disini tidak ada fitur untuk create tasks



3. Lalu tambahkan /create menjadi <https://pegawai.my.id/tasks/create> di urlnya lalu isi dan disini target saya adalah akun dummy saya yang memiliki role developer juga

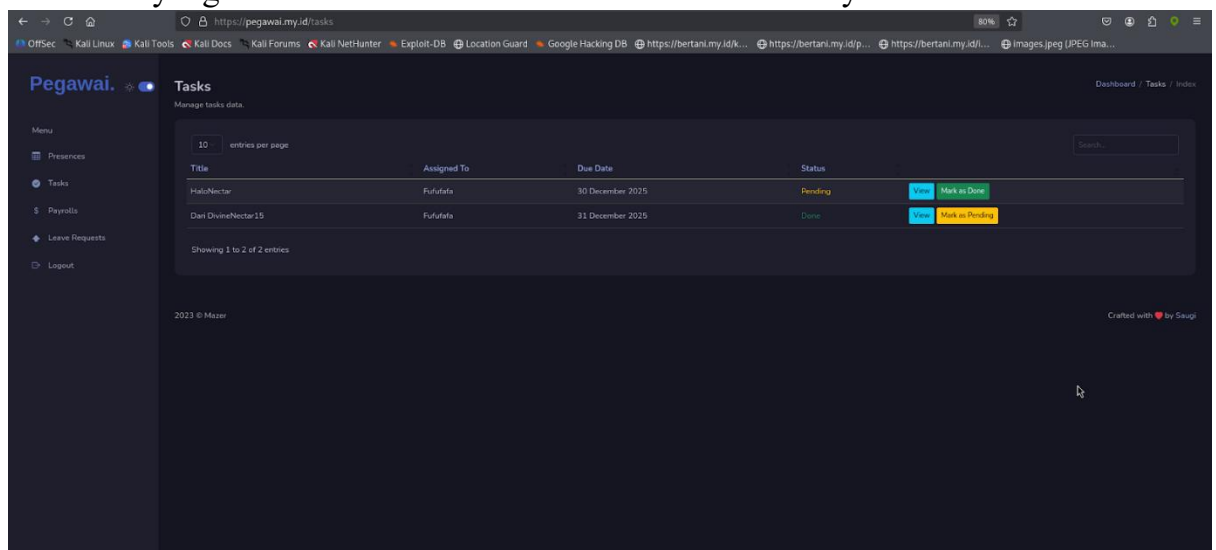


4. Tasks berhasil dibuat



5. Lalu login ke akun dummy yang menjadi target

6. Dan tasks yang kita buat tadi berhasil masuk ke akun dummy



EXPECTED RESULT

1. Akses ke endpoint `/tasks/create` seharusnya dibatasi secara ketat hanya untuk Administrator atau pengguna dengan wewenang manajerial.
2. Pengguna dengan peran *Developer* seharusnya mendapatkan respons 403 Forbidden saat mencoba mengakses URL tersebut secara langsung.
3. Kemampuan untuk memilih pengguna lain sebagai penerima tugas harus divalidasi di sisi server guna memastikan otoritas yang tepat.

ACTUAL RESULT

1. Pengguna dengan peran *Developer* dapat melewati batasan menu dan mengakses halaman pembuatan tugas melalui modifikasi URL langsung.
2. Sistem mengizinkan pengguna tersebut untuk mengisi formulir tugas dan memilih pengguna lain sebagai target penugasan.
3. Tugas yang dibuat secara tidak sah berhasil masuk dan muncul di dasbor tugas akun target.

IMPACT

1. Integritas Data Terganggu: Penyerang dapat memasukkan tugas palsu, menyesatkan, atau tidak relevan ke dalam akun rekan kerja, yang dapat mengganggu alur kerja operasional perusahaan.
2. Business Logic Bypass: Melewati batasan hierarki organisasi yang telah ditetapkan dalam sistem manajemen tugas.

RECOMMENDATION

1. Implementasi Middleware Otorisasi (Prioritas Utama): Terapkan pengecekan peran pengguna secara ketat di sisi server menggunakan *middleware* (misalnya `isAdmin` atau `can:create-tasks`) pada rute `/tasks/create`. Ini adalah solusi paling krusial untuk memastikan bahwa sistem menolak akses pengguna non-admin meskipun mereka mengetahui URL-nya.
2. Penggunaan URL yang Tidak Terprediksi (Defense-in-Depth): Sebagai lapisan pertahanan tambahan, gunakan *slug* atau UUID yang unik dan tidak berurutan daripada menggunakan rute statis yang mudah ditebak seperti `/create`. Hal ini akan mempersulit teknik *directory brute-forcing* atau *guessing* yang dilakukan oleh penyerang.

3. **Server-Side Validation:** Pastikan logika pada fungsi `store()` di *backend* memverifikasi otoritas pengguna sebelum memproses data tugas ke dalam basis data.

REFERENCES

1. **OWASP Top 10 - A01:2021 Broken Access Control:**
https://owasp.org/Top10/A01_2021-Broken_Access_Control/
2. **CWE-639: Authorization Bypass Through User-Controlled Key:**
<https://cwe.mitre.org/data/definitions/639.html>